DESKRIPSI PROGRAM

1.1 Entry Point - index.php

```php
<?php
header("Location: auth/login.php");
exit;
?>
```

Penjelasan: Mengalihkan semua akses root ke halaman login untuk security.

1.2 Konfigurasi Database - koneksi.php

```php
<?php
$host = "localhost";
$user = "root";
$pass = "";
$db   = "db_parkir";

$conn = mysqli_connect($host, $user, $pass, $db);

if (!$conn) {
    die("Koneksi gagal: " . mysqli_connect_error());
}
```

```
session_start();
define('BASE_URL', 'http://localhost/parkir-app/');

// FUNCTION: tulis_log() - Mencatat aktivitas user
function tulis_log($conn, $id_user, $isi_aktivitas) {
    $waktu = date("Y-m-d H:i:s");
    $aktivitas_safe = mysqli_real_escape_string($conn, $isi_aktivitas);

    $query = "INSERT INTO log_aktivitas (id_user, aktivitas, waktu)
              VALUES ('$id_user', '$aktivitas_safe', '$waktu')";

    return mysqli_query($conn, $query);
}
?>
```

Penjelasan: Inisialisasi koneksi database MySQLi, session management, dan fungsi logging.

1.3 Login Form - login.php

```php
<?php
require_once '../config/koneksi.php';

if (isset($_SESSION['role'])) {
```

```
    header("Location: ../" . $_SESSION['role'] . "/dashboard.php");
}
?>
<!DOCTYPE html>
<html lang="id">
<head>
    <meta charset="UTF-8">
    <title>Login - Sistem Parkir</title>
    <link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css"
rel="stylesheet">
</head>
<body>
    <div class="login-container px-4">
        <h1 class="login-title">LOGIN</h1>
        <form action="proses_login.php" method="POST">
            <input type="text" name="username" placeholder="Username" required>
            <input type="password" name="password" placeholder="Password" required>
            <button type="submit">MASUK</button>
        </form>
    </div>
</body>
</html>
```

1.4 Proses Login - proses_login.php

```php
<?php
require_once '../config/koneksi.php';

if ($_SERVER['REQUEST_METHOD'] == 'POST') {
    $username = mysqli_real_escape_string($conn, $_POST['username']);
    $password = $_POST['password'];

    $query = mysqli_query($conn, "SELECT * FROM user WHERE username = '$username'");
    $data = mysqli_fetch_assoc($query);

    if ($data) {
        if ($password == $data['password']) {  // ⚠ PLAIN TEXT COMPARISON
            $_SESSION['id_user'] = $data['id_user'];
            $_SESSION['nama']    = $data['nama'];
            $_SESSION['role']    = $data['role'];

            header("Location: ../" . $data['role'] . "/dashboard.php");
            exit;
        } else {
            echo "<script>alert('Password salah!'); window.location='login.php';</script>";
        }
    } else {
        echo "<script>alert('Username tidak ditemukan!'); window.location='login.php';</script>";
    }
```

```
}
?>
```

1.5 Logout - logout.php

```php
<?php
session_start();
session_destroy();
header("Location: login.php");
exit;
?>
```

1.6 Middleware Proteksi - middleware/auth.php

```php
<?php
function checkLogin($role_required = null) {
    if (!isset($_SESSION['id_user'])) {
        header("Location: " . BASE_URL . "auth/login.php");
        exit;
    }
```

```
    if ($role_required && $_SESSION['role'] !== $role_required) {
        die("Akses Ditolak: Anda tidak memiliki izin.");
    }
}
?>
```

1.7 Dashboard Admin - admin/dashboard.php

```php
<?php
require_once '../config/koneksi.php';
require_once '../middleware/auth.php';
checkLogin('admin');

// Query JOIN untuk log aktivitas
$log_query = mysqli_query($conn, "SELECT log_aktivitas.*, user.nama, user.role
                        FROM log_aktivitas
                        JOIN user ON log_aktivitas.id_user = user.id_user
                        ORDER BY log_aktivitas.waktu DESC
                        LIMIT 5");
?>
```

BAGIAN 2: DOKUMENTASI FUNGSI & PROSEDUR

FUNGSI #1: checkLogin($role_required)

```php
/**
 * Validasi login dan role-based access control
 * @param string|null $role_required - Role yang diperlukan
 * @return void - Redirect atau die jika gagal
 */
function checkLogin($role_required = null) {
    if (!isset($_SESSION['id_user'])) {
        header("Location: " . BASE_URL . "auth/login.php");
        exit;
    }
    if ($role_required && $_SESSION['role'] !== $role_required) {
        die("Akses Ditolak");
    }
}
```

Penggunaan:

```php
require_once '../middleware/auth.php';
checkLogin('admin');  // Hanya admin
```

FUNGSI #2: tulis_log($conn, $id_user, $isi_aktivitas)

```php
/**
 * Catat aktivitas user ke database
 * @param mysqli $conn - Koneksi database
 * @param int $id_user - ID user
 * @param string $isi_aktivitas - Deskripsi aktivitas
 * @return bool - True jika berhasil
 */
function tulis_log($conn, $id_user, $isi_aktivitas) {
    $waktu = date("Y-m-d H:i:s");
    $aktivitas_safe = mysqli_real_escape_string($conn, $isi_aktivitas);

    $query = "INSERT INTO log_aktivitas (id_user, aktivitas, waktu)
              VALUES ('$id_user', '$aktivitas_safe', '$waktu')";
    return mysqli_query($conn, $query);
}
```

QUERY #1: SELECT User by Username

```php
```

```
// Mencari user berdasarkan username untuk login
$query = mysqli_query($conn, "SELECT * FROM user WHERE username = '$username'");
$data = mysqli_fetch_assoc($query);
```

QUERY #2: INSERT User Baru

```php
// Menambah user baru dengan 4 field
$sql = "INSERT INTO user (nama, username, password, role)
        VALUES ('$nama', '$username', '$password', '$role')";
mysqli_query($conn, $sql);
```

QUERY #3: UPDATE User

```php
// Mengubah data user berdasarkan ID
$sql = "UPDATE user SET
        nama = '$nama',
        username = '$username',
        password = '$password',
        role = '$role'
        WHERE id_user = '$id'";
```

```
mysqli_query($conn, $sql);
```

QUERY #4: DELETE User dengan CASCADE

```php
// Hapus log aktivitas dulu (foreign key constraint)
mysqli_query($conn, "DELETE FROM log_aktivitas WHERE id_user = '$id'");

// Kemudian hapus user
$query = "DELETE FROM user WHERE id_user = '$id'";
mysqli_query($conn, $query);
```

QUERY #5: SELECT Dengan JOIN

```php
// Mengambil log aktivitas dengan nama user
$log_query = mysqli_query($conn, "SELECT log_aktivitas.*, user.nama, user.role
                        FROM log_aktivitas
                        JOIN user ON log_aktivitas.id_user = user.id_user
                        ORDER BY log_aktivitas.waktu DESC
                        LIMIT 5");
```

BAGIAN 3: DEBUGGING & ISSUES

🔴 ISSUE #1: SQL INJECTION - CRITICAL

Lokasi: proses_login.php line 8, admin/user/tambah.php line 12

Kode Bermasalah:

```php
$query = mysqli_query($conn, "SELECT * FROM user WHERE username = '$username'");
// Jika username input: ' OR '1'='1
// Query menjadi: SELECT * FROM user WHERE username = '' OR '1'='1'
```

Solusi dengan Prepared Statement:

```php
$stmt = mysqli_prepare($conn, "SELECT * FROM user WHERE username = ?");
mysqli_stmt_bind_param($stmt, "s", $username);
mysqli_stmt_execute($stmt);
$result = mysqli_stmt_get_result($stmt);
$data = mysqli_fetch_assoc($result);
```

🔴 ISSUE #2: PLAIN TEXT PASSWORD - CRITICAL

Lokasi: proses_login.php line 12, admin/user/edit.php line 57-59

Kode Bermasalah:

```php
if ($password == $data['password']) {  // Tidak di-hash!
// Password juga visible di form edit:
<input type="text" name="password" value="<?= $data['password']; ?>">
```

Solusi dengan Password Hashing:

```php
// Saat INSERT/UPDATE
$password_hashed = password_hash($_POST['password'], PASSWORD_BCRYPT);

// Saat LOGIN
if (password_verify($password, $data['password'])) {
    // Login berhasil
}
```

□ ISSUE #3: Missing Auth Check - HIGH

Lokasi: admin/area/tambah.php line 1-2

Kode Bermasalah:

```php
<?php
require_once '../../config/koneksi.php';
if ($_POST) {
    // Tidak ada checkLogin()! User tidak login bisa akses!
```

Solusi:

```php
<?php
require_once '../../config/koneksi.php';
require_once '../../middleware/auth.php';
checkLogin('admin');  // Tambah ini!
```

□ ISSUE #4: Hardcoded URL - LOW

Lokasi: config/koneksi.php line 14

Kode Bermasalah:

```php
define('BASE_URL', 'http://localhost/parkir-app/');  // Hardcoded
```

Solusi Dynamic:

```php
$protocol = isset($_SERVER['HTTPS']) ? 'https' : 'http';
$domain = $_SERVER['HTTP_HOST'];
define('BASE_URL', $protocol . '://' . $domain . '/parkir-app/');
```

BAGIAN 4: LAPORAN EVALUASI SINGKAT

✅ KEKUATAN SISTEM:

#	Kekuatan	Detil
1	Struktur Folder Baik	config/, auth/, middleware/, admin/ terorganisir
2	Authentication System	Login/logout functionality bekerja
3	Role-Based Access	RBAC dengan 3 role: admin, petugas, owner
4	Audit Trail	Function tulis_log() mencatat aktivitas
5	UI Responsive	Bootstrap 5 + Icons
6	Middleware Proteksi	checkLogin() di halaman penting

** ❌ KELEMAHAN SISTEM:**

#	Isu	Severity	Solusi
1	SQL Injection	CRITICAL	Prepared Statements
2	Plain Text Password	CRITICAL	Password Hash
3	Missing Auth Check	HIGH	Add checkLogin()
4	No Error Handling	MEDIUM	Add try-catch
5	Hardcoded URL	LOW	Dynamic URL
6	No CSRF Protection	MEDIUM	Add token validation
7	DB Schema Empty	MEDIUM	Create SQL file